

Data Processing Addendum

Template for customers of Decision Intel (the "Processor")

This Data Processing Addendum ("DPA") supplements the Decision Intel Subscription Agreement between [CUSTOMER LEGAL NAME] ("Controller") and Decision Intel Ltd. ("Processor"). It governs the processing of Personal Data (as defined below) that Controller provides to Processor in connection with the Services. This DPA is aligned with Article 28 of Regulation (EU) 2016/679 (GDPR) and the UK GDPR.

1. Definitions

"Personal Data" has the meaning given in GDPR Art. 4(1). "Processing" has the meaning given in GDPR Art. 4(2). "Sub-processor" means any third party engaged by Processor to process Personal Data on Controller's behalf. "Services" means the Decision Intel subscription services the Controller has contracted. All terms not defined in this DPA have the meaning given in the Subscription Agreement or GDPR.

2. Subject-matter, duration, nature and purpose

Processor processes Personal Data solely to provide the Services — analysing strategic memos, board decks and related decision artefacts for cognitive biases, structural assumptions and decision-quality signals — and to produce the Decision Provenance Record (DPR) that documents that processing. Processing continues for the term of the Subscription Agreement unless terminated earlier in accordance with it.

3. Sub-processors

Controller authorises Processor to engage the following Sub-processors:

- Google LLC (Gemini API) — LLM inference for bias and structural-assumption detection. Google commits not to use customer inputs or outputs to train its models under its Vertex AI terms.
- Anthropic PBC (Claude API) — fallback LLM inference when AI_FALLBACK_ENABLED is set. Anthropic commits not to use customer inputs or outputs to train its models under its commercial terms.
- Supabase Inc. — PostgreSQL database, authentication and file storage. SOC 2 Type II certified.
- Vercel Inc. — application hosting and edge compute. SOC 2 Type II certified.
- Resend (for transactional email) — notifications and session-management flows only.

Processor will notify Controller at least 30 days before adding or replacing a Sub-processor. Controller may object in writing; the parties will in good faith work to resolve the objection or, failing agreement, Controller may terminate the affected Services.

4. Security measures

Processor maintains the following technical and organisational measures, commensurate with the state of the art:

- Encryption at rest of document content using AES-256-GCM with key-version rotation (DOCUMENT_ENCRYPTION_KEY protocol).
- Encryption in transit via TLS 1.2 or higher on all public endpoints.
- A GDPR anonymizer node runs as the first stage of the analysis pipeline; no analysis model ever receives raw PII.
- Per-user and per-organisation access scoping with audit-log retention.
- Role-based access to production systems with SSO and least-privilege grants.
- Incident response plan with 72-hour notification commitment for confirmed Personal Data breaches.

5. Retention and deletion

Default retention windows by tier (subject to the Order Form):

- Free tier: 30 days from upload.
- Individual tier: 90 days from upload.
- Strategy tier: 12 months from upload.
- Enterprise tier: configurable, 360-day default.

Controller may request deletion of any document at any time via the in-app Delete action or by written notice to privacy@decision-intel.com. Processor will soft-delete within 24 hours and permanently purge within 30 days, except where retention is required to comply with applicable law.

6. Data subject rights

Processor will, at Controller's reasonable request and cost, assist Controller in responding to data-subject rights requests under GDPR Articles 15-22 (access, rectification, erasure, restriction, portability, objection, and automated-decision rights). The Decision Provenance Record serves as the meaningful-information-about-the-logic artefact required by Article 22.

7. Data residency and international transfers

Processor's primary processing region is the United States. Application hosting (Vercel) and database / file storage (Supabase) operate from US-region infrastructure. There is no EU-region or African-region processing option in production today; Controllers requiring a specific regional processing commitment should contact privacy@decision-intel.com before contract execution to discuss feasibility.

Where Processing involves transfer of Personal Data from the European Economic Area, the United Kingdom, or another jurisdiction whose data-protection law restricts cross-border transfer, the parties rely on the Standard Contractual Clauses (Commission Implementing Decision (EU) 2021/914), the UK International Data Transfer Addendum, or the equivalent standard mechanism for the originating jurisdiction (including, where applicable, NDPR cross-border transfer requirements for Nigerian data subjects). These clauses are incorporated by reference. Processor will not transfer Personal Data to any third country whose data-protection law would prevent the application of an appropriate transfer mechanism.

8. Audit rights

Processor will, on reasonable written request (not more than once per year, unless a breach is suspected), make available to Controller or its independent auditor (subject to reasonable confidentiality obligations) the information necessary to demonstrate compliance with this DPA. Processor shares current SOC 2 and third-party security reports on written request.

9. Return or destruction of Personal Data

On termination of the Services, Controller may export its data for 30 days. After that window, Processor will delete Personal Data per Section 5, except where retention is required to comply with applicable law.

10. Governing law and notices

This DPA is governed by the law specified in the Subscription Agreement. Notices under this DPA are sent to the respective contacts listed in the Order Form. For Processor: privacy@decision-intel.com.

11. Evidentiary standard & audit-trail continuity

Each Decision Provenance Record we produce carries a deterministic evidentiary-standard fingerprint binding the DQI methodology version, the SHA-256 hash of the input document, the prompt fingerprint, the DQI weight-resolution hash, and the record schema. We will not change the evidentiary standard underlying your records without versioning the change and preserving the prior fingerprint series, so that a multi-year reasoning-provenance trail built for EU AI Act Article 14, Basel III Pillar 2 ICAAP, SOX §404, or SEC AI-disclosure purposes remains internally consistent and any change of standard is a disclosed, reconstructable event rather than a silent substitution. On termination, the fingerprint series is included in the data export under §10A so the trail remains independently verifiable after the engagement ends.

Signatures

Controller: _____ Date: _____

Name / Title: _____

Processor (Decision Intel Ltd.): _____ Date: _____

Name / Title: _____

This template is provided for evaluation by Controller procurement. Executed version is governed by the Order Form and any negotiated addenda.